

Анализ APK: Belbet

Разработчик: AKARON • Package: com.winmove.step • Версия: 1.0 (versionCode 1)
Название в Google Play: Belbet • label внутри APK: Win Move
Разобраны файлы: com.winmove.step-1.apk, com.winmove.step-1-config.en.apk,
com.winmove.step-1-config.xxhdpi.apk

SDK / стек

Параметр	Значение
Название приложения	Belbet (label в APK: Win Move)
Android Gradle Plugin	8.7.3
minSdk	26
targetSdk	36
Kotlin	да 2.0.21
Web View	да
Custom Tabs	нет
Рекламные сети	нет
Аналитика	нет
Permissions	android.permission.INTERNET, android.permission.ACCESS_WIFI_STATE, android.permission.ACCESS_NETWORK_STATE, com.winmove.step.DYNAMIC_RECEIVER_NOT_EXPORTED_PERMISSION, com.android.vending.CHECK_LICENSE
Libraries	kotlin-stdlib 2.0.21, kotlinx-coroutines-core/android 1.7.3, OkHttp 4.12.0, androidx.appcompat 1.7.0, androidx.activity 1.9.3, androidx.core / core-ktx 1.13.1, androidx.fragment 1.5.4, androidx.lifecycle 2.8.7, androidx.room 2.6.1, androidx.recyclerview 1.1.0, androidx.viewpager 1.0.0, androidx.viewpager2 1.0.0, androidx.constraintlayout, androidx.emoji2 1.3.0, androidx.startup 1.1.1, androidx.profileinstaller 1.3.1, androidx.savedstate 1.2.1, androidx.sqlite 2.4.0, androidx.transition 1.5.0, androidx.cardview 1.0.0, androidx.coordinatorlayout 1.1.0, androidx.drawerlayout 1.1.1, androidx.customview 1.1.0, androidx.loader 1.0.0, androidx.vectordrawable 1.1.0, androidx.versionedparcelable 1.1.1, androidx.databinding viewbinding 8.7.3, Google Material Components 1.12.0, com.pairip.application / com.pairip.licensecheck
Подозрительные домены	нет
SharedPreferences	файл cfg, ключ rurl — после проверки туда записывается внешняя ссылка; при следующем запуске приложение сразу открывает сохранённый адрес
Есть ли клоака	да
Подозрительные слова	rurl, cfg, ?app=, workers.dev, X-Device-Model, User-Agent, Accept-Language, loadUrl, webView, WebViewClient, file:///android_asset/index.html, licensecheck, CHECK_LICENSE

Какие данные собираются

- имя пакета приложения
- модель телефона
- строка браузера устройства

Как собираются

Сведения собираются один раз, в самый первый момент работы приложения — на первом же экране, сразу после запуска, ещё до того как человек успеет что-то нажать. Никакого заставочного экрана или кнопки «начать» перед этим нет: код единственного экрана приложения сначала настраивает встроенное окно сайта, а потом сразу берёт нужные сведения.

Приложение ничего не спрашивает у пользователя и не показывает окно с разрешениями: все три сведения оно получает у самой системы Android напрямую. Имя пакета — это внутреннее название приложения, оно берётся из системного описания самого приложения. Модель телефона читается из системного справочника об устройстве. Строка браузера устройства — это то, как встроенный браузер телефона представляется сайтам; её приложение получает у системного движка веб-страниц.

Все названия, которые для этого нужны (адрес проверки, названия полей, имя файла настроек), в APK не лежат открытым текстом. Они спрятаны: в коде хранятся наборы чисел, и отдельная маленькая функция превращает их в обычный текст уже во время работы приложения по постоянному ключу из четырёх чисел. Из-за этого простой поиск по строкам внутри APK ни адреса, ни названий полей не находит — их приходится расшифровывать вручную.

Человек этого шага не замечает совсем: нет ни запроса разрешений, ни сообщения, ни задержки, о которой сказали бы вслух. Отдельно стоит сказать, что рекламный номер устройства, идентификатор Android, язык или страна телефона в этом приложении не читаются — при полном разборе кода запуска таких обращений к системе нет.

Куда отправляются

Сразу после запуска приложение тихо, в фоне, обращается по адресу <https://small-hill-2ea7.vcheslavzelen2022.workers.dev/> и добавляет к нему признак `?app=com.winmove.step`. Полный адрес запроса выглядит как <https://small-hill-2ea7.vcheslavzelen2022.workers.dev/?app=com.winmove.step>. Это бесплатная площадка Cloudflare для маленьких серверных программ (домен `workers.dev`), а не сайт какого-то известного сервиса или рекламной сети.

Адрес собирается из кусков прямо во время работы: сначала расшифровывается постоянная часть с именем сайта, затем к ней приклеивается «`?app=`», а затем — внутреннее название самого приложения. Запасных адресов в коде нет, адрес ровно один. Обращение уходит обычным запросом на чтение страницы, без отправки данных в теле сообщения — модель телефона и строка браузера устройства передаются в служебной шапке этого запроса.

Запрос выполняется в фоновом потоке, поэтому экран не «замирает» и человек ничего не видит. Ждать ответа приложение готово около десяти секунд. Сам этот адрес в памяти приложения не сохраняется — в память попадает только та ссылка, которую сервер выдаст в ответ. Она записывается в маленький файл настроек внутри приложения (файл `cfg`, запись `url`) и остаётся там до удаления приложения или очистки его данных.

Важная деталь: в описании приложения включено разрешение на обычные, незащищённые соединения (`usesCleartextTraffic`). То есть если сервер уведёт приложение на адрес без шифрования, оно всё равно туда пойдёт.

Как фильтруются пользователи

Само приложение никого не фильтрует. В коде нет ни списка стран, ни списка языков, ни проверки на бота, ни проверки на эмулятор, ни каких-либо условий вида «если страна такая — показать то». Единственное сравнение, которое приложение делает на телефоне, к признакам пользователя вообще не относится: оно лишь смотрит, перебрал ли его сервер на другой адрес или нет.

Решение «кому показать внешнюю страницу, а кому оставить обычное приложение» целиком принимает сервер на стороне Cloudflare. Признаки, по которым он может это делать, ему передаёт само приложение: внутреннее название приложения (в адресе запроса), модель телефона и строка браузера устройства (в служебной шапке запроса). Дополнительно сервер, как любой сайт, видит сетевой адрес телефона, а значит и приблизительную страну — но это уже свойство самого соединения, отдельного поля с географией в коде приложения нет.

Отдельно стоит обратить внимание на поле языка в запросе. Приложение отправляет его жёстко заданным, всегда одним и тем же значением `en-US,en;q=0.9`, а не настоящим языком телефона. Настоящий язык устройства приложение не читает вообще. То есть язык здесь не признак для отбора людей, а маскировка: запрос выглядит так, будто его сделал обычный англоязычный браузер.

Логика самого сервера в APK, конечно, не лежит, поэтому точных правил отбора по коду приложения не видно. По коду видно ровно две вещи: приложение отправляет перечисленные признаки и затем полностью подчиняется решению сервера. Проверка выполняется только один раз — при первом запуске; если сервер тогда выдал ссылку, дальше приложение к серверу уже не обращается и открывает сохранённую ссылку сразу.

Что возвращается

Ответ сервера читается очень необычным способом: содержимое страницы приложение не разбирает вообще. Ни текста, ни полей вида `url` или `offer` оно из ответа не берёт. Приложение смотрит только на одно: остался ли адрес тем же, по которому он обращался, или сервер по дороге перебрал его на другой адрес.

Работает это так. Приложение запоминает адрес, который отправляло, и сравнивает его с адресом, на котором в итоге оказалось. Если сервер отвечает переадресацией, встроенный сетевой механизм автоматически идёт по ней дальше, и конечный адрес оказывается другим. Именно этот конечный адрес и есть «ответ», который приложению нужен.

Вариант, выгодный для схемы: адреса не совпали — значит сервер увёл приложение на какую-то внешнюю страницу. Тогда этот новый адрес считается целевой ссылкой, запоминается в настройках приложения (файл `cfg`, запись `url`) и открывается.

«Белый» вариант: адрес не изменился, сервер просто ответил своей страницей без переадресации. Тогда никакая ссылка не сохраняется и приложение работает как обычное. Тот же исход наступает, если запрос вообще не удался — нет интернета, сервер не ответил или истекли десять секунд ожидания: приложение молча остаётся в обычном режиме, никакой ошибки человеку не показывают.

Как показывается оффер или белая версия

Если адреса разошлись, то есть сервер перебросил приложение на внешнюю страницу, приложение прячет своё встроенное окно сайта и передаёт полученную ссылку наружу — в обычный браузер телефона отдельным окном. То есть человек видит не страницу «внутри приложения», а привычный браузер с открытым сайтом. Происходит это сразу после запуска, без промежуточных экранов и без нажатий: между стартом приложения и открытием браузера проходит лишь время одного сетевого запроса.

Куда именно ведёт эта ссылка, по коду сказать нельзя: она не заложена в APK, её каждый раз выдаёт сервер. Судить о ней можно только по обвязке — карточка в магазине называется Belbet (название букмекерского бренда), тогда как внутри APK приложение называется Win Move и никакого отношения к ставкам не имеет. Такое расхождение названий — типичный признак «белой оболочки», через которую заводят людей на страницу ставок или казино.

Ссылка запоминается насовсем. При каждом следующем запуске приложение даже не обращается к серверу: оно сразу берёт сохранённый адрес и снова открывает браузер. Больше того, браузер открывается заново каждый раз, когда человек возвращается в приложение, — выйти из этого поведения, не очистив данные приложения, нельзя.

Если же ответ «белый», человеку просто остаётся обычное приложение: встроенное окно сайта показывает страницу, лежащую внутри APK, и никакого перехода на внешние адреса не происходит. Тот же обычный режим включается и когда попытка открыть браузер не удалась.